

Authentication Protocols

Prepared by

Jesna J S

Assistant Professor, CSE TKMCE

Course Outcomes: After the completion of the course, the student will be able to

CO1	Explain authentication protocols, X.509 authentication service and Public Key Infrastructure (PKI).(Cognitive Knowledge Level: Understand)
CO2	Identify the security mechanisms in E mail security services. (Cognitive Knowledge Level: Understand)
CO3	Summarize the network and transport layer security services provided in a secure communication scenario. (Cognitive Knowledge Level: Apply)
CO4	Describe real time communication security and application layer security protocols. (Cognitive Knowledge Level: Apply)
CO5	Explain the concepts of firewalls and wireless network security. (Cognitive Knowledge Level: Understand)

Syllabus

Module-1 (Authentication Protocols)

Authentication Protocols – Mutual authentication, One way authentication. Kerberos – Kerberos Version 4, Kerberos Version 5. X.509 Authentication service. Public Key Infrastructure (PKI) – Trust models, Revocation.

Module-2 (E-mail Security)

Pretty Good Privacy (PGP) – Operational Description, Cryptographic keys and key rings, Message format, PGP message generation, PGP message reception, Public key management. S/MIME – Functionality, Messages, Certificate processing, Enhanced security services.

Module-3 (Network Layer Security and Web Security)

Internet Protocol Security (IPSec) – Overview, IP security architecture, Authentication Header (AH), Encapsulating Security Payload (ESP), Combining Security Associations, Key management. Internet Key Exchange (IKE) - Phases. Web Security – Web security considerations. Secure Socket Layer and Transport Layer Security (SSL/TLS) – SSL Architecture, SSL protocols, Cryptographic computations, Transport layer security.

Module-4 (Real-time Security and Application Layer Security)

Real-time communication security – Perfect Forward Secrecy (PFS), Denial-of-Service protection, Endpoint identifier hiding, Live partner reassurance. Hypertext Transfer Protocol Secure (HTTPS) – Connection initiation, Closure. Secure Shell (SSH) – Transport layer protocol, User authentication protocol, Connection protocol. Secure Electronic Transaction (SET) – Overview, Features, Participants, Dual signature, Payment processing.

API ABUL KALAM

Module-5 (System Security and Wireless Security)

Firewalls – Firewall characteristics, Types of Firewalls, Firewall configurations, Encrypted Tunnels, Trusted systems – Data access control, The concept of Trusted Systems, Trojan horse defense. IEEE 802.11i wireless LAN security - Services, Phases of operation, Wired Equivalent Privacy (WEP), Wi-Fi Protected Access (WPA), WPA2.

Text Books

1. William Stallings, Cryptography and Network Security Principles and Practice, 4/e, Pearson Ed.
2. C. Kaufman, R. Perlman and M. Speciner, “Network Security: Private Communication in a Public World”, 2/e, PHI.

References

1. Behrouz A. Forouzan, DebdeepMukhopadhyay, “Cryptography and Network Security”, 3/e, Tata McGraw Hill.
2. Tyler Wrightson, “Wireless Network Security A Beginner’s Guide”, 2012, Tata McGraw Hill.
3. William Stallings, “Network Security Essentials: Applications and Standards”, 4/e, Prentice Hall.
4. Schiller J., Mobile Communications, 2/e, Pearson Education.
5. Roberta Bragg et. al., “Network Security: The Complete Reference”, Tata McGraw Hill

Topics Include:

- Authentication Protocols
 - ✓ Mutual authentication
 - ✓ One way authentication
- Kerberos
 - ✓ Version 4
 - ✓ Version 5

Authentication Protocols

- **Authentication** means *verifying the identity* of a user, device, or system.
- In cryptography, **authentication protocols** are structured methods that confirm:
 - ✓ **Who** is communicating (identity verification)
 - ✓ **That the message is genuine** (not altered)
 - ✓ **That both sides agree on a secret** (secure session keys)
- These protocols protect networks from imposters, replay attacks, and man-in-the-middle attacks etc.

Imposter Attack (Impersonation Attack)

- An attacker **pretends to be a legitimate user** or system to gain unauthorized access.
- **How Imposters Attack Happens**
 - ✓ Attacker steals login credentials
 - ✓ Attacker steals session cookies
 - ✓ Attacker forges identity (fake username, fake certificate, etc.)
 - ✓ Attacker sits in the middle and pretends to be someone else

Replay Attack

- An attacker **captures a valid message** and **re-sends (replays)** it later to fool the system.

One-Way Authentication

- Only **one party proves its identity to the other.**
- The authentication happens in **one direction.**
- Logging into a website: You verify yourself to the server.
- HTTPS websites: Browser checks the **server's certificate**, but the server does not verify the user.
 - ✓ Client sends login details (username/password) OR verifies server certificate.
 - ✓ Server checks and grants access.

Mutual Authentication

- **Both parties** prove their identity to each other.
- Authentication happens in **two directions**.
 - Client → proves identity to server
 - Server → proves identity to client
 - Only after both succeed , secure communication begins

Both client and server authenticate each other.

Strong protection against:

- Man-in-the-Middle attacks
- Impersonation
- Replay attacks

More secure but slightly complex

Kerberos

- Kerberos is an authentication protocol
- It is named after the three-headed dog Greek mythology that guards the gates of Hades.
- Originally designed at MIT, it has gone through several versions.
- **Kerberos runs as a third-party trusted server known as the Key Distribution Center (KDC) and symmetric-key cryptography.**
- Kerberos was designed for an environment where a user logs into a workstation by providing a username and a password.

Configuration:

- Three servers are involved in the Kerberos protocol:
 1. **Authentication server (AS)**
 2. **Ticket-granting server (TGS)**
 3. **A real (data) server that provides services to others**

Authentication Server (AS)

- The authentication server (AS) is the KDC in the Kerberos protocol.
- Each user registers with the AS and is granted a user identity and a password.
- The AS has a database with these identities and the corresponding passwords.
- The AS verifies the user, issues a session key to be used between client and the TGS, and sends a ticket for the TGS.

Ticket-Granting Server (TGS)

- The ticket-granting server (TGS) issues a ticket for the real server.
- It also provides the **session key ($K_{A\ B}$) between client and server**.
- Kerberos has separated user verification from the issuing of tickets. In this way, though **Alice(client) verifies her ID just once with the AS, she can contact the TGS multiple times to obtain tickets for different real servers.**

Real Server

- The real server (Bob) provides services for the user (Alice).
- Kerberos is designed for a client-server program, such as FTP, in which a user uses the client process to access the server process.
- Kerberos is not used for person-to-person authentication.

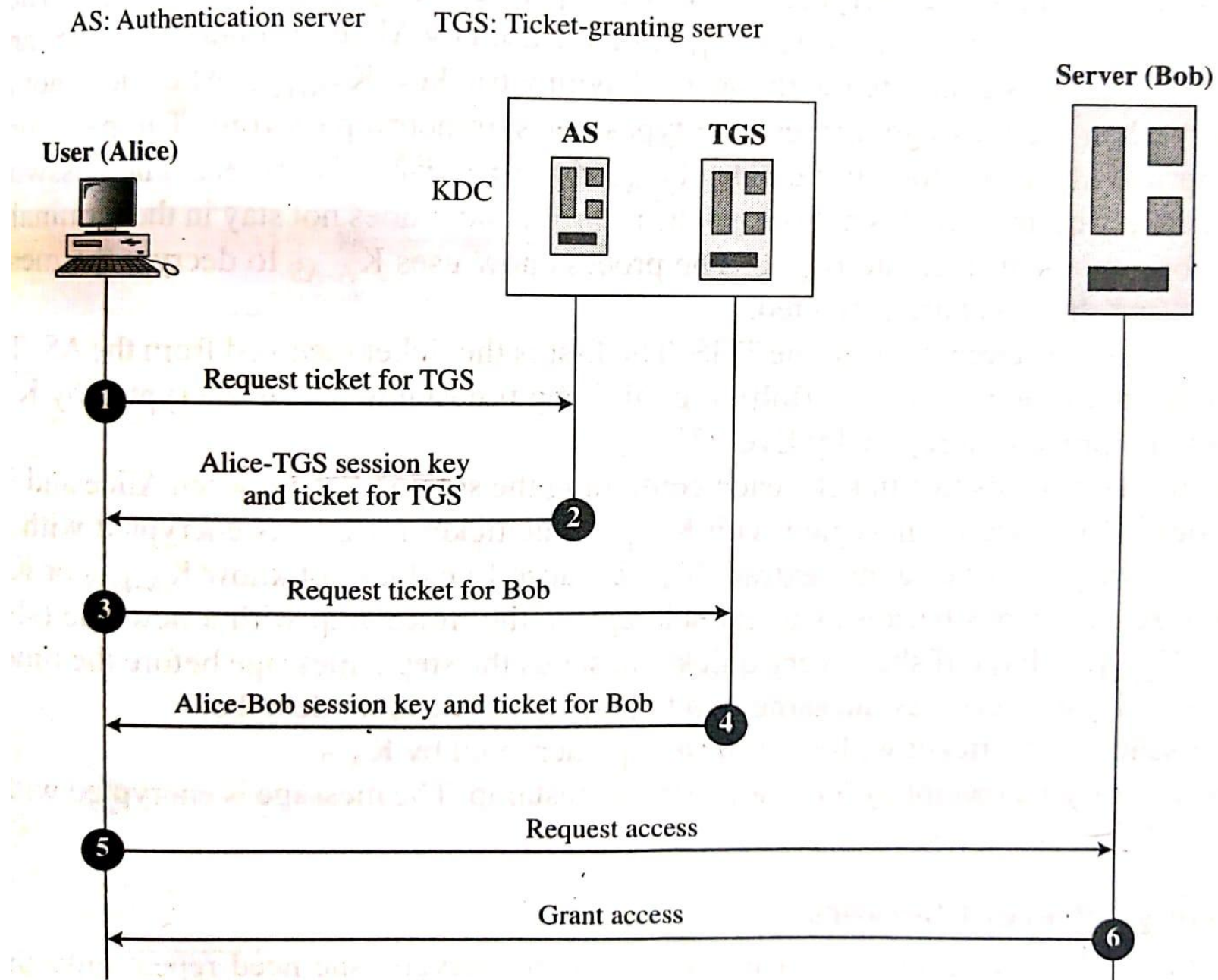


Fig. 15.7 Kerberos servers

The Process and Messages

- The primary steps involved in Kerberos protocol are
 1. **Step 1: Login**
 2. **Step 2: Obtaining a service granting ticket**
 3. **Step 3: User contact Server for accessing the service.**

Step 1: Login

➤ The user, Alice, sits down at an arbitrary public workstation and enters her name.

- The workstation **sends her name in plain text to the AS.**
- In response AS performs the following actions.

1. First **creates a package of username and a randomly generated session key(KS)**
2. It encrypts this package with the **symmetric key that the AS shares with the TGS.** The output of this step is called **TGT (Ticket Granting Ticket)**
3. The AS then combines the **TGT with the session key(KS)** and **encrypts the two** together using symmetric key derived from the **password** of Alice.

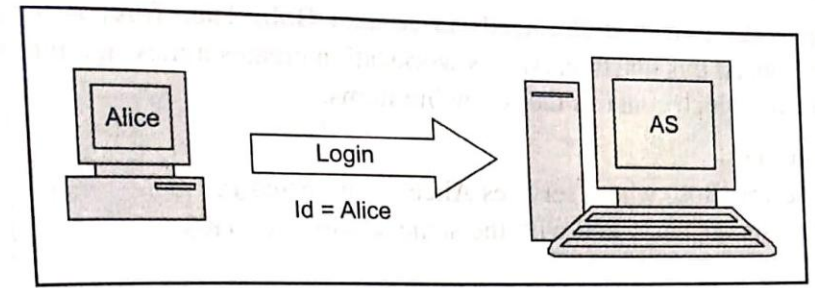


Fig. 7.36 Alice sends a login request to AS

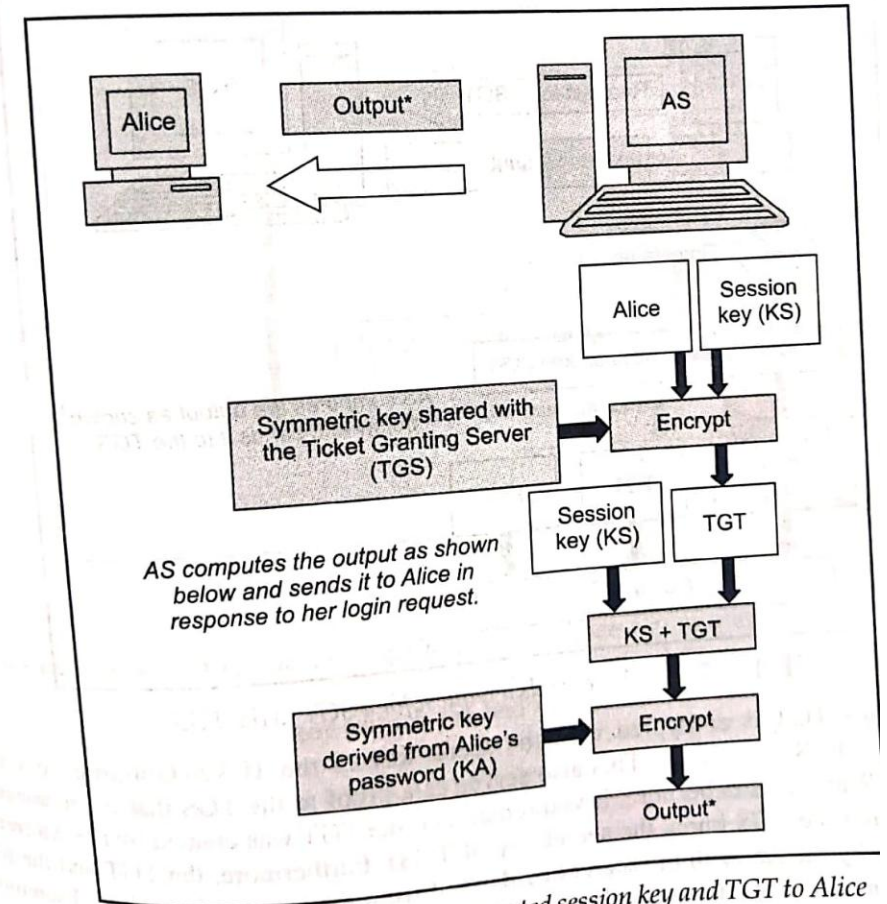


Fig. 7.37 AS sends back encrypted session key and TGT to Alice

- After this message is received, Alice's workstation asks her for the password.
- When the Alice enters it, the workstation generates the symmetric key(K_A) derived from the password and uses that key to extract the session key & TGT.
- The workstation destroys the password of Alice from its memory immediately to prevent it from attacks.

Step 2: Obtaining a service granting ticket

- Alice needs a Ticket to communicate with server.
- So, Alice workstation creates a message intended for TGS which contains the following items:
 1. TGT (Ticket Granting Ticket)
 2. ID of Server
 3. Current Timestamp encrypted with the same session key (KS)

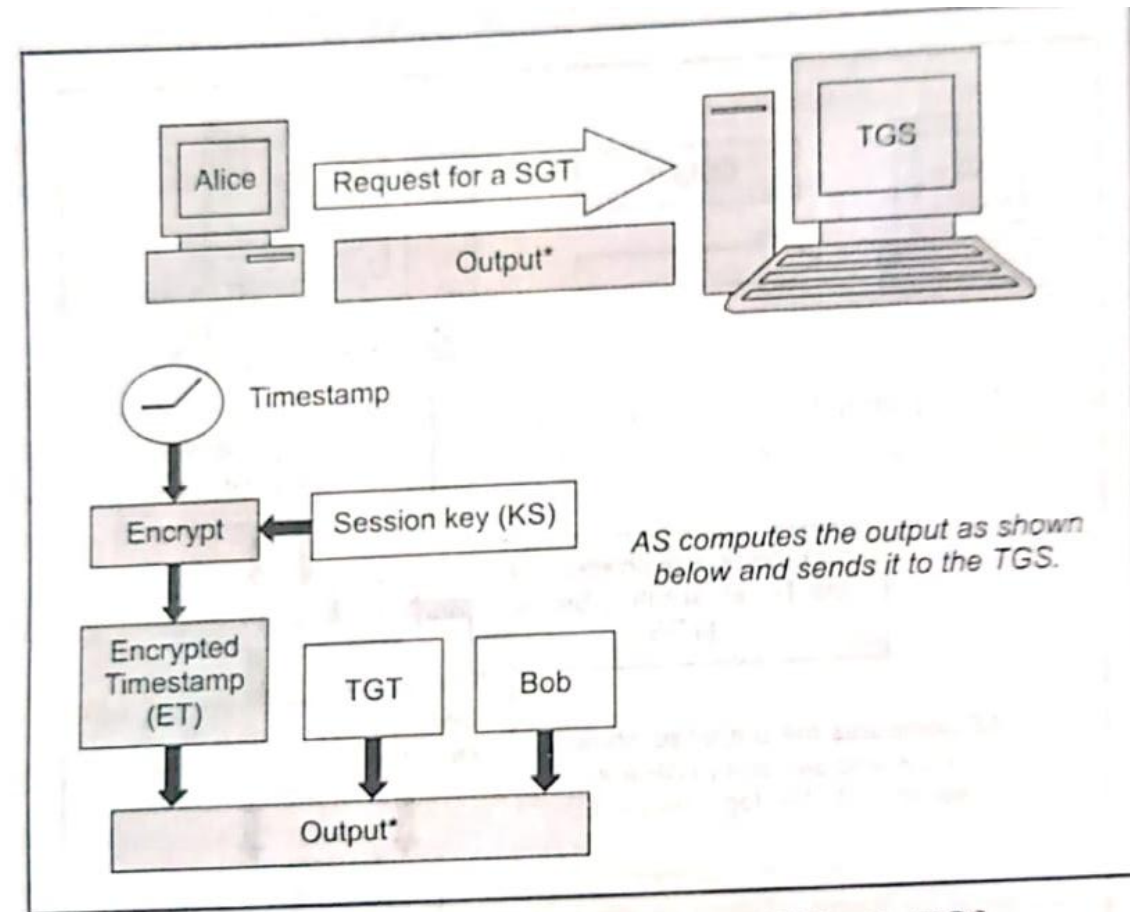


Fig. 7.38 Alice sends a request for a SGT to the TGS

- Once the TGS is satisfied of the credentials of Alice, the TGS creates a session key K_{AB} , for Alice to have secure communication with Bob.
- TGS sends its twice to Alice:
 1. Combined with Bob's id and encrypted with session key(KS).
 2. Combined with Alice's id and encrypted with the session key(KB)

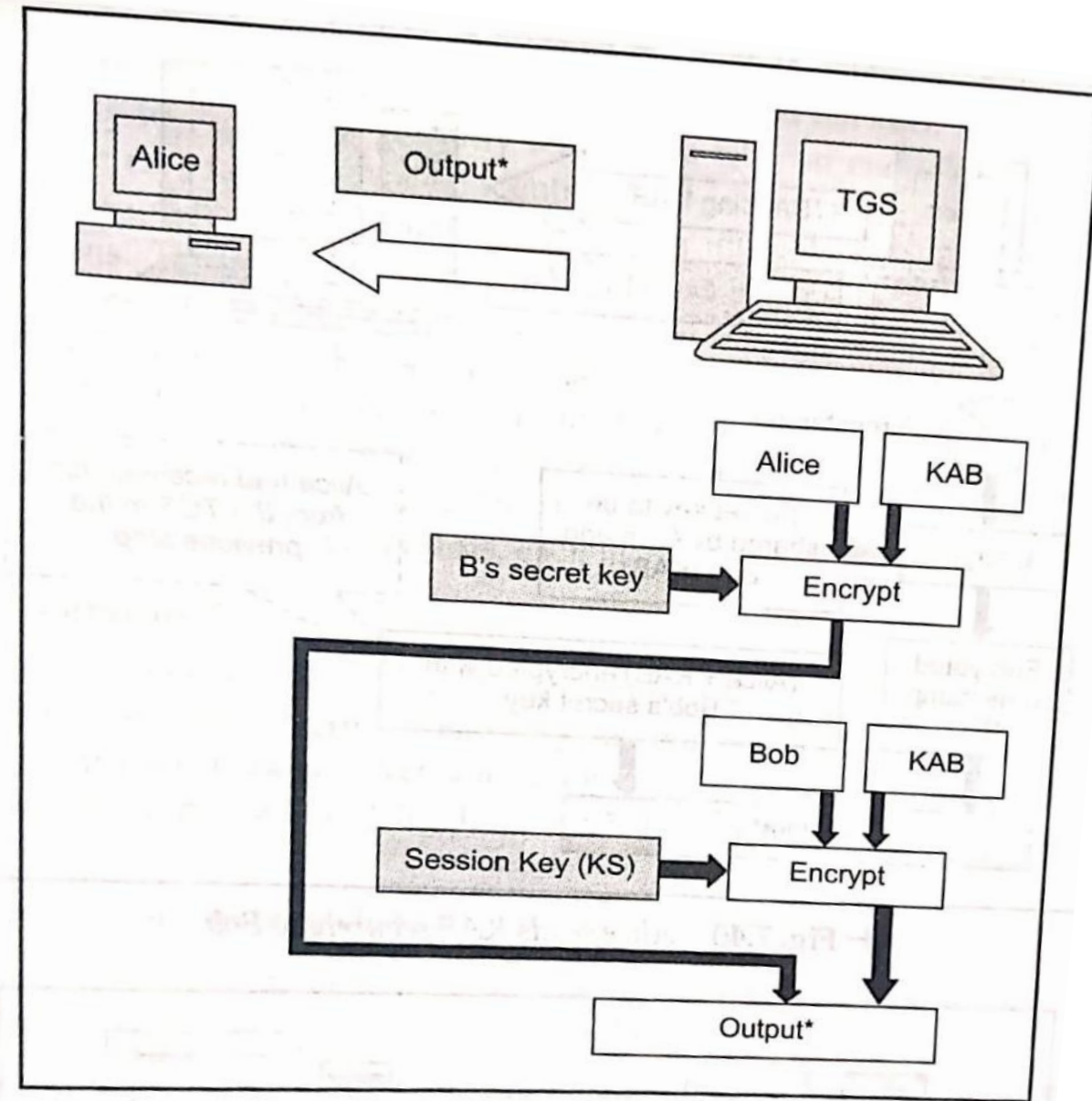


Fig. 7.39 TGS sends response back to Alice

now send K_{AB} to

Step 3: User contact Server for accessing the service

- Alice now sends a KAB to Bob in order to enter a session with him.
- Since only Bob has his secret key, he uses it to first and obtain the info.
- From this gets the key KAB, which he uses to decrypt the encrypted timestamp.
- **Bob now adds 1 to the timestamp sent by Alice, encrypt the result with KAB & send it back to Alice.**
- Now Alice and Bob can communicate with each other.

Note:

- If Alice wants to communicate to another server, then she can, simply needs to obtain another shared key from the TGS.
- Since Alice needs to authenticate or sign on only once, this mechanism is called **Single Sign On (SSO)**.

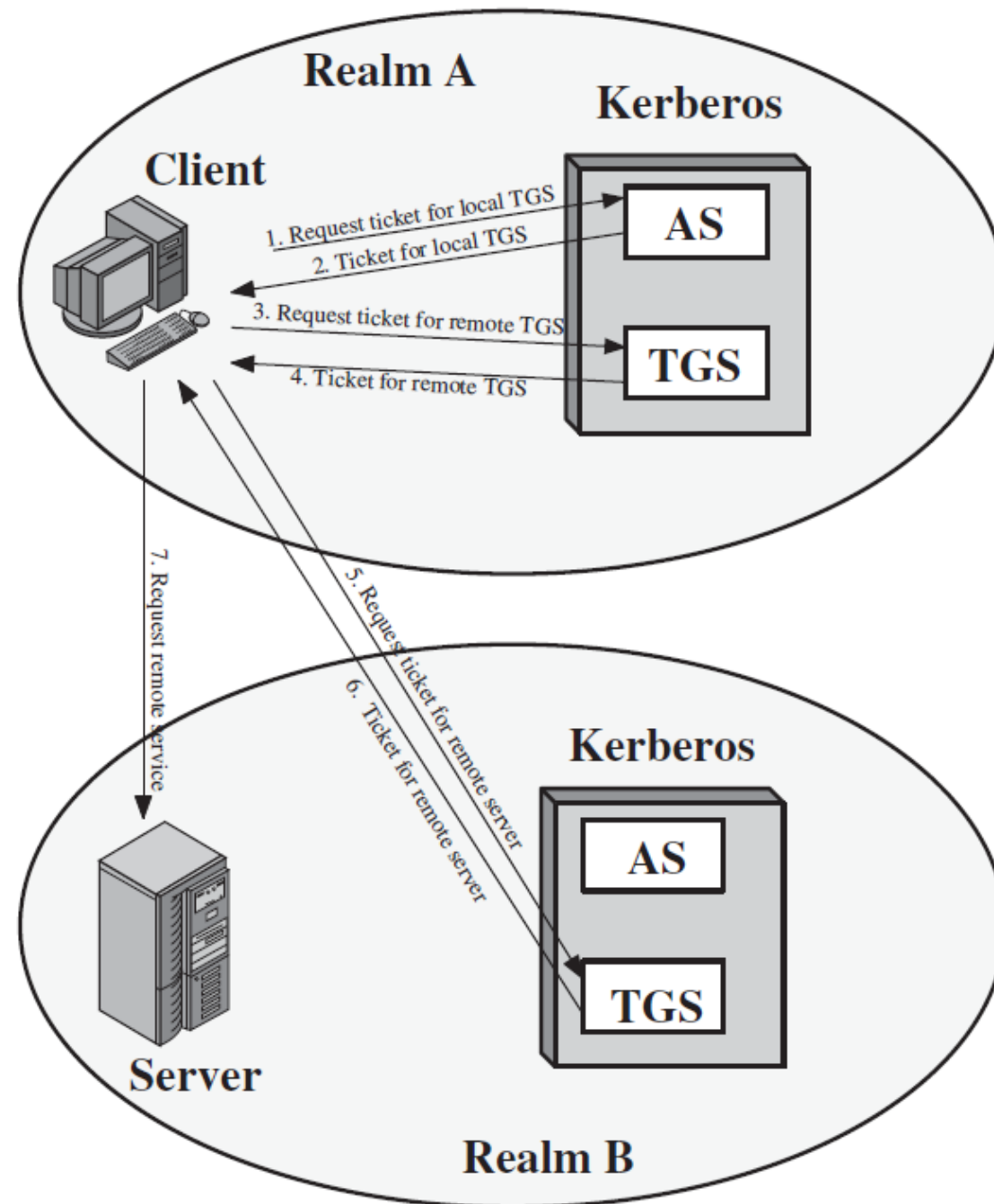


Figure 4.2 Request for Service in Another Realm

Kerberos 5

- Kerberos version 5 is specified in RFC 4120 and provides a number of improvements over version 4.

DIFFERENCES BETWEEN VERSIONS 4 AND 5

- Version 5 is intended to address the limitations of version 4 in two areas: environmental shortcomings and technical deficiencies.
- Kerberos version 4 did not fully address the need to be of general purpose. This led to the following **environmental shortcomings**.

1. Encryption system dependence:

- ✓ Kerberos V4 depended on only one type of encryption (DES).
- ✓ If DES became weak or insecure, the whole system would become unsafe.

2. Internet protocol dependence:

- ✓ Kerberos V4 worked only with Internet Protocol (IP).

3. Message byte ordering:

- Different computers store data in memory using different byte orders (big-endian / little-endian).
- Kerberos V4 did not clearly define byte ordering, causing communication errors between different systems.

4. Ticket lifetime:

- Kerberos V4 had a fixed maximum ticket lifetime.
- Short lifetime caused frequent re-authentication and long lifetime increased the risk of misuse if stolen.

5. Interrealm authentication:

- Authentication between different organizations (realms) was limited.
- Kerberos V4 supported only two connected realms at a time.

Technical deficiencies in the version 4 protocol itself.

1. **Double encryption:** Some messages were encrypted twice unnecessarily.
2. **Session keys:** Session keys were generated in a **weak or limited way**.
3. **Password attacks:** Kerberos V4 was vulnerable to offline password guessing attacks.

Summary of Kerberos Version 5 Message Exchanges

(1) $C \rightarrow AS$ $Options \parallel ID_c \parallel Realm_c \parallel ID_{tgs} \parallel Times \parallel Nonce_1$

(2) $AS \rightarrow C$ $Realm_c \parallel ID_C \parallel Ticket_{tgs} \parallel E(K_c, [K_{c,tgs} \parallel Times \parallel Nonce_1 \parallel Realm_{tgs} \parallel ID_{tgs}])$

$Ticket_{tgs} = E(K_{tgs}, [Flags \parallel K_{c,tgs} \parallel Realm_c \parallel ID_C \parallel AD_C \parallel Times])$

(a) Authentication Service Exchange to obtain ticket-granting ticket

(3) $C \rightarrow TGS$ $Options \parallel ID_v \parallel Times \parallel Nonce_2 \parallel Ticket_{tgs} \parallel Authenticator_c$

(4) $TGS \rightarrow C$ $Realm_c \parallel ID_C \parallel Ticket_v \parallel E(K_{c,tgs}, [K_{c,v} \parallel Times \parallel Nonce_2 \parallel Realm_v \parallel ID_v])$

$Ticket_{tgs} = E(K_{tgs}, [Flags \parallel K_{c,tgs} \parallel Realm_c \parallel ID_C \parallel AD_C \parallel Times])$

$Ticket_v = E(K_v, [Flags \parallel K_{c,v} \parallel Realm_c \parallel ID_C \parallel AD_C \parallel Times])$

$Authenticator_c = E(K_{c,tgs}, [ID_C \parallel Realm_c \parallel TS_1])$

(b) Ticket-Granting Service Exchange to obtain service-granting ticket

(5) $C \rightarrow V$ $Options \parallel Ticket_v \parallel Authenticator_c$

(6) $V \rightarrow C$ $E_{Kc,v} [TS_2 \parallel Subkey \parallel Seq\#]$

$Ticket_v = E(K_v, [Flags \parallel K_{c,v} \parallel Realm_c \parallel ID_C \parallel AD_C \parallel Times])$

$Authenticator_c = E(K_{c,v}, [ID_C \parallel Realm_c \parallel TS_2 \parallel Subkey \parallel Seq\#])$

(c) Client/Server Authentication Exchange to obtain service

Parameter	Meaning
C	Client (User requesting authentication)
AS	Authentication Server
TGS	Ticket Granting Server
V	Service/Application Server
IDc	Client Identity (Username)
IDtgs	Ticket Granting Server Identity
IDv	Service Server Identity
Realmc	Client's Realm (Domain)
Realmtgs	TGS Realm
Realmv	Service Server Realm
Options	Special request flags (forwardable, renewable, etc.)

Times	Validity period of the ticket
Nonce1, Nonce2	Random numbers to prevent replay attacks
Kc	Client's secret key (derived from password)
Ktgs	Secret key of the Ticket Granting Server
Kv	Secret key of the Service Server
Kc,tgs	Session key between Client and TGS
Kc,v	Session key between Client and Service Server
Tickettgs	Ticket used to access the TGS
Ticketv	Service ticket used to access the application server

Authenticator _c	Proof of client identity with timestamp
TS ₁	Timestamp to prevent replay attack
AD _c	Client's IP address
Flags	Permissions associated with the ticket
E(K, Data)	Data encrypted using key K